CISCO SECURE WORKLOAD

NIST SP 800-207A

ZTA Logical Components — PDP/PEP/PA/PIP Mapping

Prepared for: [Customer Name]

Prepared by: Cisco Systems, Inc.

Date: [Month Year] | Version 1.0 | Cisco Confidential

Regulatory Standard: NIST SP 800-207A (Public Draft) — ZTA Model for Access Control in Cloud-Native & Multi-Cloud Environments
Environment: Hybrid (On-Premises + AWS / Azure / GCP)
Deployment Stage: Fresh Installation

DRAFT DOCUMENT NOTICE: NIST SP 800-207A is currently in public draft / comment stage. This report is based on the stable logical component model (PDP, PEP, PA, PIP) which is architecturally consistent with SP 800-207 and unlikely to change materially. Sections derived from draft-specific content are marked [DRAFT REF]. Verify against the final published standard before use in formal audit submissions.

Executive Summary

NIST SP 800-207A extends the foundational Zero Trust Architecture standard (SP 800-207) by providing a concrete implementation model focused on cloud-native and multi-cloud environments. Where 800-207 defines the seven tenets and logical architecture, 800-207A operationalizes the Policy Decision Point (PDP), Policy Enforcement Point (PEP), Policy Administrator (PA), and Policy Information Point (PIP) into deployment workflows, use cases, and access transaction models.

Cisco Secure Workload (CSW) maps directly onto the 800-207A logical component model. CSW's software sensor functions as the PEP at the workload level. Its policy workspace is the PA. Its telemetry and vulnerability data feed the PIP. And its policy engine evaluates access decisions as the PDP — making CSW one of the most complete single-product implementations of the 800-207A access control model for workload and east-west traffic protection.

800-207A vs. 800-207 — Key Distinction

Standard	Focus	Primary Audience	CSW Relevance
NIST SP 800-207	Seven ZTA tenets, logical architecture, deployment models	CISOs, architects	Tenet-level mapping (see companion doc)
NIST SP 800-207A	PDP/PEP/PA/PIP component model, access transaction flow, cloud-native ZTA implementation	GRC, security engineers, cloud architects	Component-level mapping (this document)

Logical Component Coverage Summary

800-207A Component	CSW Implementation	Coverage
Policy Decision Point (PDP)	CSW policy engine evaluates every workload-to-workload access request against allowlist rules derived from ADM and operator policy	**Full Coverage**
Policy Enforcement Point (PEP)	CSW software sensor enforces allow/deny decisions at the workload level — inline, before connection is established	**Full Coverage**
Policy Administrator (PA)	CSW policy workspace authors, versions, deploys, and audits all policy decisions with full change history	**Full Coverage**
Policy Information Point (PIP)	CSW telemetry (flow, process, vulnerability, ADM baseline) provides the asset posture data that informs PDP decisions	**Full Coverage**

Subject (Requesting Entity)	CSW captures process-user context per access request. Non-person entities identified by process hash + workload identity	**Partial Coverage**
Enterprise Resource	CSW manages and enforces access to every monitored workload as an individual enterprise resource	**Full Coverage**
Control Plane	CSW cluster (SaaS or on-prem) operates as the ZTA control plane — policy authoring, distribution, and telemetry aggregation	**Full Coverage**
Data Plane	CSW software sensor on each workload operates as the data plane enforcement layer	**Full Coverage**

PDP/PEP/PA/PIP — Component-by-Component Mapping

1. Policy Decision Point (PDP)

800-207A Definition: The PDP evaluates access requests and produces a decision — allow, deny, or redirect. It consumes input from the PIP and applies policy authored by the PA. In 800-207A, the PDP operates on every access transaction, not just on session establishment.

CSW PDP Implementation	Detail
Policy Engine	CSW's policy engine evaluates every network flow against the active allowlist policy workspace. Each connection attempt is a discrete access transaction — evaluated in real time against source workload identity, destination workload, port, and protocol.
ADM-Derived Policy Input	PDP decisions are informed by ADM-established baseline: approved source-destination pairs, approved ports, and approved protocols. The ADM output is the primary policy input — not manually authored static rules.
Vulnerability-Aware Decisions	CSW PDP can incorporate workload vulnerability state into access decisions via compensating control policies. A workload with a critical unpatched CVE triggers a more restrictive policy set — posture-aware PDP evaluation consistent with 800-207A's dynamic policy model.
Real-Time Evaluation	Every access transaction is evaluated in real time — not cached from prior sessions. This satisfies 800-207A's requirement that PDP decisions be continuous rather than session-establishment-only.
Decision Logging	Every PDP decision (allow or deny) is logged in CSW forensic telemetry with full context: timestamp, requesting workload, target resource, policy rule matched, and outcome.

Evidence generated: Policy decision log (allow/deny per flow), policy workspace export, ADM-to-policy traceability report.

2. Policy Enforcement Point (PEP)

800-207A Definition: The PEP grants, monitors, and can terminate connections between a subject and an enterprise resource. It acts on PDP decisions and sits inline between the requesting subject and the target resource. In 800-207A, the PEP must operate at the resource level — not just at network perimeters.

CSW PEP Implementation	Detail
Workload-Level Inline Enforcement	CSW software sensor (tetd) operates inline on every monitored workload — not at a network gateway. This satisfies 800-207A's requirement for PEP enforcement at the resource level, enabling per-workload access control independent of network topology.
Pre-Connection Enforcement	CSW enforces allow/deny decisions before a connection is established at the workload level. Denied connections never reach the target application — the PEP blocks at the network stack layer.

Connection Termination	CSW can terminate existing connections when policy changes (e.g., a workload is isolated via API during incident response). This satisfies 800-207A's requirement that PEPs can terminate as well as prevent connections.
Multi-Environment PEP Consistency	CSW PEP operates identically on on-premises Linux/Windows workloads and cloud VMs (AWS EC2, Azure VM, GCP instance). A uniform enforcement layer across all environments — a specific 800-207A cloud-native requirement.
Agentless PEP via Cloud Connectors	For cloud workloads where agent installation is not feasible, CSW cloud connectors provide agentless PEP-equivalent enforcement via cloud-native security group/NSG policy push.

Evidence generated: PEP enforcement log (connections blocked/allowed per workload), sensor deployment inventory, connection termination log.

3. Policy Administrator (PA)

800-207A Definition: The PA establishes and/or shuts down communication paths between subjects and resources. It translates PDP decisions into specific policy configurations deployed to PEPs. The PA must maintain a complete, auditable record of all policy changes.

CSW PA Implementation	Detail
Policy Workspace	CSW policy workspace is the PA implementation — where operators author allowlist rules, organize policies by scope, set enforcement priorities, and deploy to the PEP layer (sensors). The workspace is the authoritative source of all active policy.
ADM-to-Policy Translation	The PA function includes translating ADM-discovered application flows into deployable policy rules. CSW automates this: ADM output is imported directly into the policy workspace as a proposed policy set for operator review and approval.
Simulation Mode (PA Safety Function)	Before deploying policy to PEPs, CSW PA runs in Simulation mode — validating that new policy decisions do not break approved application flows. No policy is enforced without simulation validation.
Version History & Audit Trail	Every policy change in the CSW workspace is timestamped, attributed to the operator, and retained in version history. This is the PA change audit trail required by 800-207A for governance and forensic review.
Policy Lifecycle Management	CSW PA manages the full policy lifecycle: Draft → Simulation → Enforcement → Retired. Policies can be rolled back to prior versions. Stale rules are identified and flagged for retirement after ADM re-runs.
API-Driven PA Automation	The PA function can be automated via CSW REST API — enabling SOAR platforms, CMDB systems, and orchestration tools to push policy changes programmatically, enabling the dynamic PA behavior required by 800-207A.

Evidence generated: Policy workspace version history, simulation run log, operator change attribution log, API-driven policy change log.

4. Policy Information Point (PIP)

800-207A Definition: The PIP is the source of attribute information used by the PDP to make access decisions. In 800-207A, the PIP must provide continuous, real-time signals across three domains: identity attributes, device/workload posture, and environmental context.

CSW PIP Implementation	Detail
Workload Posture (Device PIP)	CSW provides continuous workload posture data: CVE presence and severity (CVSS), patch status, running process inventory, process hash integrity, and listening port baseline — the device/workload posture PIP feed required by 800-207A.
Network Context (Environmental PIP)	CSW ADM provides environmental context: current communication patterns, newly observed flows, protocol compliance state, and lateral movement indicators — informs PDP decisions about whether current access patterns are normal or anomalous.

Process-Identity Context (Subject PIP)	CSW captures the requesting process identity per access transaction: process name, hash, parent process, and user context — the non-person entity (NPE) subject attribute required by 800-207A's service-to-service access model.
SIEM Integration (Aggregated PIP)	CSW streams all PIP signals to SIEM via Kafka/Syslog — enabling the enterprise-wide PIP aggregation model described in 800-207A, where the PDP consumes signals from multiple PIPs (identity, device, network, threat intelligence).
Complementary PIP Sources	CSW PIP covers workload posture and network context. For complete 800-207A PIP coverage, pair with: identity provider (user attributes), EDR (endpoint behavioral signals), and threat intelligence platform (external threat context).

Evidence generated: Vulnerability posture feed (continuous), process inventory export, ADM environmental context report, SIEM integration telemetry.

800-207A Access Transaction Model — CSW Walkthrough

NIST 800-207A defines a specific access transaction flow that every ZTA implementation must support. The following traces a workload-to-workload access transaction through CSW's implementation of the 800-207A model.

[DRAFT REF] — Access transaction model from 800-207A public draft. Component sequence reflects the stable logical model; specific details may evolve in final publication.

Step	800-207A Event	CSW Implementation
1	Subject initiates access request to enterprise resource	Service A (workload) initiates TCP connection to Service B (workload) on port 443
2	PEP intercepts the access request	CSW sensor on Service B intercepts the inbound connection attempt before it reaches the application
3	PEP requests access decision from PDP	CSW sensor queries the local policy engine (distributed PDP) with: source IP, source workload identity, destination port, protocol
4	PDP queries PIP for subject and resource attributes	Policy engine queries: workload labels (scope membership), vulnerability state, process baseline (known process?), ADM baseline (approved flow?)
5	PDP evaluates policy and issues decision	Policy engine evaluates connection against active allowlist workspace: match found → ALLOW; no match → DENY
6	PA is notified of decision for enforcement	Decision is logged in CSW telemetry with full context. If DENY: policy violation alert fired to SIEM/SOAR
7	PEP enforces decision — allow or deny connection	CSW sensor allows TCP handshake to complete (ALLOW) or drops the packet (DENY) before application layer
8	Continuous monitoring during session	CSW monitors the active connection for duration, bytes transferred, and behavioral deviation from ADM baseline throughout session lifetime
9	PEP terminates connection if policy changes mid-session	If an isolation policy is pushed via API during the session, CSW sensor terminates the active connection immediately

800-207A ZTA Use Cases — CSW Coverage

[DRAFT REF] — The following use cases are drawn from the public draft of 800-207A. CSW coverage is assessed against stable architectural requirements within each use case.

Use Case 1 — Enterprise with Satellite Facilities

An enterprise with headquarters and multiple branch/satellite facilities implementing ZTA to eliminate implicit trust for branch-to-HQ and branch-to-branch traffic.

Requirement	800-207A Expectation	CSW Implementation	Status
Branch workload isolation	Branch resources treated as untrusted — no implicit access to HQ resources	CSW scopes segment branch workloads. Default-deny prevents branch-to-HQ lateral access without explicit policy.	**Full Coverage**
Per-resource access control	Access to individual HQ resources granted per-session, not per-network	CSW workload-level allowlist: branch workloads can only reach specifically approved HQ workloads on approved ports.	**Full Coverage**
Consistent PEP across locations	PEP enforcement must be consistent regardless of physical location	CSW software sensor deployed identically at HQ and all branch sites. Same policy workspace governs all sensors.	**Full Coverage**
East-west visibility	All inter-facility traffic must be visible and policy-governed	CSW ADM maps all cross-facility flows. Policy workspace governs all east-west traffic — no unmonitored paths.	**Full Coverage**

Use Case 2 — Multi-Cloud Enterprise

An enterprise operating workloads across multiple cloud providers implementing ZTA to enforce consistent access policy across cloud boundaries and eliminate implicit cloud-internal trust.

Requirement	800-207A Expectation	CSW Implementation	Status
Unified policy across clouds	Single policy model governs access regardless of cloud provider	CSW single policy workspace governs workloads on AWS, Azure, GCP, and on-prem. No per-cloud policy fragmentation.	**Full Coverage**
Cloud workload PEP	PEP must enforce at workload level — not just cloud security groups/NSGs	CSW software sensor on cloud VMs provides workload-level PEP. More granular than security group enforcement alone.	**Full Coverage**
Cross-cloud flow visibility	All cross-cloud traffic must be visible and policy-controlled	CSW ADM maps cross-cloud flows. Cloud connectors provide VPC/VNET flow visibility and reveal unexpected cross-cloud dependencies.	**Full Coverage**

Cloud identity integration	Cloud workload identity must be incorporated into access decisions	CSW uses cloud provider tags (AWS, Azure, GCP labels) to drive scope membership and policy — cloud identity informs PDP.	**Full Coverage**
Agentless cloud coverage	Not all cloud workloads support agent installation	CSW cloud connectors provide agentless coverage via VPC Flow Logs. Visibility coverage; enforcement via cloud-native controls.	**Partial Coverage**

Use Case 3 — Collaboration Across Enterprise Boundaries

An enterprise enabling controlled collaboration with external partners implementing ZTA to provide scoped, audited access to specific internal resources without granting broad network access.

Requirement	800-207A Expectation	CSW Implementation	Status
External partner isolation	Partner access strictly scoped to specific resources — no lateral movement	CSW External-Partners scope enforces isolation. Partners can only reach explicitly allowlisted resources. No lateral access possible.	**Full Coverage**
Per-partner audit trail	All partner access must be individually auditable	CSW flow telemetry captures all partner-initiated connections with full context. Per-partner flow export available for audit.	**Full Coverage**
Dynamic partner policy	Partner access can be granted and revoked dynamically	CSW API enables real-time policy updates: grant access by adding allowlist rule, revoke by removing it — no network reconfiguration needed.	**Full Coverage**
Minimum necessary access	Partners receive access only to what their role requires	CSW workload-level allowlist: partner X can reach Resource A on port 443 only. No access to any other workload.	**Full Coverage**
Identity-aware partner access	Partner identity must be verified, not just network location	CSW enforces the network path to authentication. Full identity verification requires complementary IdP/ZTNA integration.	**Partial Coverage**

Gap Analysis — Complementary Controls for Full 800-207A Coverage

800-207A Requirement	CSW Coverage	Gap	Complementary Control
User identity attributes for PDP	Partial — process/NPE identity only	Human user identity, MFA state, and role attributes not natively in CSW	Cisco Secure Access (SSE/ZTNA) + Okta/Azure AD
Continuous session re-evaluation for users	Partial — workload sessions monitored	User session re-evaluation (step-up auth, session revocation) not in CSW scope	Cisco Secure Access, Duo Security
Device certificate / 802.1X authentication	Partial — network path enforced	Certificate-based device authentication is not a CSW function	Cisco ISE, Cisco Secure Client
Threat intelligence PIP feed	Partial — internal telemetry only	External threat intel (IOCs, threat actor TTPs) not natively ingested by CSW	Cisco XDR, Cisco Talos
North-south user-to-app access control	Partial — east-west primary	CSW is optimized for east-west. North-south user access needs ZTNA	Cisco Secure Access (ZTNA/SWG)

Evidence Package for 800-207A Assessment

Component	Evidence Artifact	CSW Source	Frequency
PDP	Policy decision log (allow/deny per flow)	Investigate → Flow Search	Continuous
PDP	ADM-to-policy traceability report	ADM Workspace + Policy Workspace	Quarterly
PEP	Sensor deployment inventory	Manage → Agents	Monthly
PEP	Connection enforcement log (blocks)	Alerts → Policy Violations	Real-time
PA	Policy workspace version history	Defend → Workspace History	Per change
PA	Simulation run validation log	Defend → Simulation Mode	Per policy change
PIP	Vulnerability posture report (workload)	Investigate → Vulnerability	Weekly
PIP	Process baseline + anomaly log	Alerts → Process Anomaly	Real-time
PIP	ADM environmental context report	Investigate → ADM	Quarterly
All	SIEM telemetry integration config	Platform → Data Export	Continuous